

Ejercicio 3:

Compare la efectividad de una sesión tradicional de identificación de riesgos (liderada únicamente por el Gerente de Proyectos con una lista de verificación) frente a una sesión de Risk Storming con todo el equipo multifuncional. ¿Por qué este último enfoque es más adecuado para detectar riesgos técnicos y de ciberseguridad en la arquitectura del software?

Respuesta:

La sesión tradicional puede ser útil como punto de partida, pero una sesión de Risk Storming con un equipo multifuncional suele ser más efectiva para descubrir riesgos técnicos y de ciberseguridad. La razón principal es que combina diferentes conocimientos, perspectivas y responsabilidades sobre la arquitectura, en lugar de depender de la visión limitada del Gerente de Proyectos.

Comparación de enfoques

Criterio	Sesión tradicional	Risk Storming multifuncional
Participantes	Principalmente el Gerente de Proyectos	Desarrolladores, arquitectos, especialistas DevOps, seguridad, operaciones, QA, usuarios y negocio
Herramienta principal	Lista de verificación y experiencia del gerente	Tormenta estructurada de ideas, revisión de arquitectura y discusión colaborativa
Cobertura	Riesgos conocidos y generales	Riesgos conocidos, emergentes, técnicos, operativos y de seguridad
Perspectiva	Centralizada y posiblemente limitada	Diversa y especializada

Detección de dependencias	Puede pasar por alto interacciones entre componentes	Permite analizar integraciones, flujos de datos y responsabilidades compartidas
Riesgos de ciberseguridad	Puede identificar amenazas comunes, pero no necesariamente vulnerabilidades específicas	Facilita descubrir fallas de autenticación, autorización, secretos, exposición de datos y configuración
Participación del equipo	El equipo puede asumir un papel pasivo	Los participantes son corresponsables de identificar y tratar los riesgos
Resultado	Registro inicial de riesgos	Registro enriquecido con causas, consecuencias, propietarios, controles y acciones de mitigación

Las listas de verificación son valiosas porque ayudan a no olvidar riesgos recurrentes y aprovechan la experiencia de proyectos anteriores. Sin embargo, normalmente reflejan riesgos ya conocidos; por eso pueden no detectar problemas nuevos derivados de una tecnología, integración o arquitectura específica.

¿Por qué el Risk Storming es Superior para Detectar Riesgos Técnicos y de Ciberseguridad?

El Risk Storming es superior para detectar riesgos técnicos y de ciberseguridad porque analiza el sistema de forma colaborativa, específica y orientada a “qué puede salir mal”, en vez de limitarse a comprobar riesgos genéricos de una lista. Reúne a quienes realmente conocen el código, la arquitectura, la infraestructura, los datos y la seguridad, por lo que reduce puntos ciegos.

Esta combina conocimientos especializados, ya que, en un proyecto de software, ningún rol conoce todo el sistema con el mismo nivel de detalle, como lo pueden ser:

- El arquitecto identifica dependencias, límites de confianza, puntos únicos de fallo y decisiones de diseño.
- Los desarrolladores conocen el código, las APIs, las librerías externas y los posibles errores de implementación.
- DevOps o infraestructura conoce configuraciones de nube, redes, contenedores, despliegues, permisos y respaldos.
- QA identifica escenarios no probados, fallos de integración y casos extremos de uso.
- El especialista de seguridad analiza vulnerabilidades, vectores de ataque, controles y posibles abusos.
- El área de negocio conoce qué datos, procesos y servicios son críticos para la organización.

Esto hace que el riesgo se observe desde varias perspectivas. OWASP describe el modelado de amenazas como un ejercicio de equipo que involucra, entre otros, a propietarios de producto, arquitectos, responsables de seguridad y probadores de seguridad.